WOODEX INTERIOR - DIGITAL OPERATIONS

Woodex Admin v2.5 Pro - Master Plan

Woodex Admin v2.5 Pro - Master Plan

Target version: Admin **v2.5 Pro** - the React + TypeScript rebuild of the Woodex master dashboard **Strategy:** rewrite the front end - version the back end - preserve the data **Based on:** PROJECT-ANALYSIS-REPORT-2026-10-13.pdf (26 pages, 13 branches, 365 API actions measured) **Prototype:** admin-v25/ - 5 working screens, all 65 routes registered, 70 render checks passing **Date:** 13 October 2026 - **Branch:** arena/4150341e-marketingwoodex

1. Executive summary

Woodex already has the hard part: 365 working server actions, a 20-table database holding real leads, quotations and invoices, 150 public pages, and integrations with WhatsApp, Telegram, Google and an AI assistant. What it does not have is an interface architecture that can carry the next five years, and it has never had a clean production boundary.

This plan keeps everything that works and replaces what does not:

Layer	Decision	Why
Front end	Rewrite in React 18 + TypeScript + Vite	The current admin is 60 IIFE modules, 10,502 lines, sharing 56 mutable VIEWS keys and loading in script order. Three of the four shipped admin copies contain duplicate fragments that break parsing. Nothing about that is repairable in place.
Back end	Version, don't rewrite - api/v2/ in PHP 8.2 over the same MySQL	The 365 actions encode years of business rules that already work. Rewriting them buys nothing and risks everything. Instead: one front controller, a typed envelope, safe persistence, and a capability table.
Data	Preserve - same MySQL, migrate the JSON side-stores in with SQL	wx_leads (32 columns, 4 indexes) is real business data. It is extended, not replaced.
Design	One token contract, two first-class themes ("Woodex Ink")	Ends the v2.1 defect where the sidebar was pinned dark with !important and 21 modules carried 343 literal colours, so the obsidian theme only half-applied.
Delivery	Incremental - v2.1 stays live while v2.5 is built screen by screen	A working studio system must never go dark. Cut over one route at a time behind a flag.

What this delivers: a master dashboard that opens on one honest screen - pipeline, revenue, what needs attention today - and reaches all 57 screens (plus 4 new v2.5 modules) through a typed registry, on a back end where money is calculated on the server, JSON writes cannot corrupt state, and 8 Critical + 28 High open findings are closed rather than carried forward.

What it does not do: it does not put a Node server in production. Hostinger stays Apache + PHP + MySQL. The React build is static files. That keeps hosting cost at zero and risk low.

1.1 Headline targets

Metric	Today (v2.1 Pro)	v2.5 Pro target
Admin modules	64 JS files, no build step	~90 TS modules, one build, content-hashed assets
Bundle	67 unversioned <script> tags, ~1.2 MB vendor	app ~ 80 kB gz + vendor chunks, immutable cache
View registry	62 keys, 20 registered by 2+ modules	1 route = 1 component, typed
Literal colours	343 across 21 files (being swept)	0 - enforced by lint
Auth token	HMAC bearer in sessionStorage (XSS-readable)	HttpOnly SameSite=Lax cookie + CSRF
Money maths	recalculated in the browser	server-computed only
JSON persistence	file_put_contents(..., LOCK_EX) truncates first	flock around read-modify-write or MySQL
Critical findings	8 open	0
High findings	28 open (5 fixed pending verification)	0 open, or accepted in writing
Route coverage by test	manual	every route render-tested in CI

2. Where the project stands

Measured in the analysis report. The short version:

Strong. 365 server actions across 40 PHP files; 20 MySQL tables / 161 columns; 150 public pages with 142 sitemap URLs; working WhatsApp Cloud API, Telegram bot, Google Analytics 4 + Search Console, Google Sheets sync, MCP endpoint for Claude/Codex/Cursor, and a 25-document audit pack.

Fragile.

Problem	Evidence	Consequence
Four admin generations coexist	admin/ (v1), wf-admin/ (v2 serverless), frontend-v1/admin/ (v2.0), 3 x v2.1	Nobody can say which build is deployed
main does not contain the product	PR #4 -> #5 -> #6 chain never merged	Support answers are wrong by default
JSON side-stores hold secrets and state	28 files under _private/	Non-atomic writes; protection is .htaccess only
Documents are opaque blobs	quotations, invoices, projects, templates all LONGTEXT JSON	Cannot query, index or validate business records
Credentials published	151 files / 36 locations; repository public	8 Critical findings, release recommendation BLOCK
No build step	67 unversioned script tags; load order is the contract	Cannot refactor safely; no cache busting

3. Product definition - what "master dashboard" means

The master dashboard is not a settings page. It is the studio's operating screen and it must answer four questions in under five seconds, for the person who opens it:

1. **What is happening?** - open pipeline value, new leads, won this month, conversion rate.
2. **What needs me now?** - approvals waiting on the master, leads with no reply, failed campaigns.
3. **What is the money doing?** - quoted vs won, average deal size, win rate by service line.

4. **Is the machine healthy?** - site health, backups, integrations, unanswered questions.

Everything else is reachable in one keystroke from the command palette.

3.1 Design principles

#	Principle	Concretely
1	One screen, one job	A screen that cannot state its purpose in one line is two screens
2	Density is a setting, not a guess	comfortable and compact change row, control and page height together
3	Never lie about state	No success toast without a request; no total that has not been saved
4	Money is server-side	The browser projects; the server decides
5	Every route is reachable	Registry + aliases + command palette; unknown paths are a real 404
6	Zero literal colour	Components read semantic tokens only
7	A screen is done when it renders for every role, empty and broken	Acceptance gate, enforced in CI

---

4. Design system - "Woodex Ink" (recommended)

Recommendation: ship both themes with a three-accent switcher, at two densities, driven by a single semantic token contract. Light follows the DESIGN.md direction (white surfaces, blue #2563eb); dark is the obsidian/cyan palette the v2.1 release already shipped (#08090c surfaces, cyan #00d3f2 accent, gold brand mark). Nothing else is per-theme.

4.1 The contract

A component may reference **only** semantic tokens. It may never reference a primitive (ink-800) or a hex value.

```
primitive --ink-900 --cyan-400 --gold-500 <- palette, theme-agnostic
?
semantic --bg --surface --border --text --accent --ok --warn --danger
--viz-1...6 --grid --shadow-* --r-* --s-* --z-*
?
component background: var(--surface); color: var(--text);
```

33 semantic tokens cover the whole product. The prototype implements the full set in admin-v25/src/styles/tokens.css - switch theme, accent and density on the Theme screen and every other screen follows, including the charts.

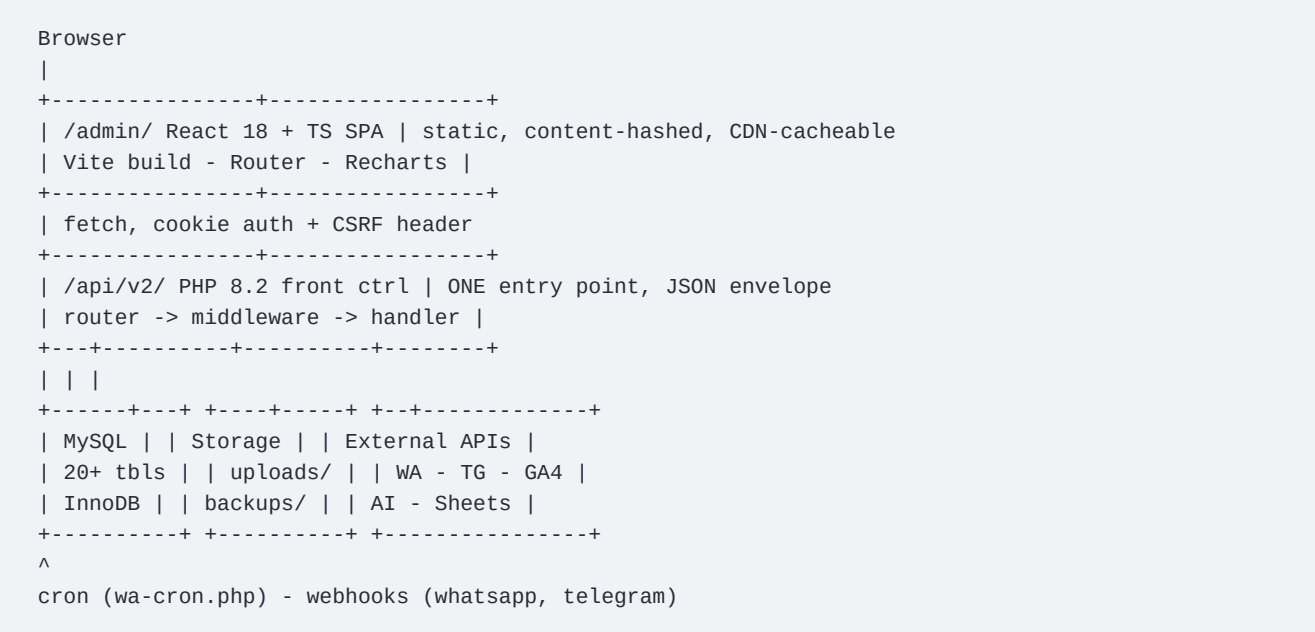
4.2 Rationale for the choices

Decision	Choice	Reason
Theme	Both, dark default for the studio	Daylight readability for quotes and PDFs; obsidian for long sessions and the projector in a client meeting
Accent	Blue (light) / Cyan (dark), plus Gold and Violet as user options	Blue-gold is the brand; cyan is the product signature the team already recognises
Density	Per user, stored in the account	A quotation desk wants 34 px rows; a designer reviewing images wants 44 px
Type	Inter, 11-28 px, tabular numerals in tables	Already loaded in the current build; numbers must align in columns
Radius	4 / 6 / 8 / 12 / 16	Matches the existing card language so v2.1 screens do not feel foreign
Motion	90 / 150 / 240 ms, honoured prefers-reduced-motion	Nothing decorative; state changes only
Status colour	One statusTone() map for the whole product	Stops "Partial" being green here and amber there

4.3 What this fixes from v2.1

v2.1 defect	Replacement
AD-6 sidebar pinned dark with !important	one --sidebar token, both themes
RC-3 343 literal colours in 21 modules	semantic tokens + a lint rule that fails the build
Charts stayed blue in dark mode	charts read resolved tokens through useTokens()
Token names disagreed (--txt vs --tx)	one published list, checked by the token test

5. Architecture



5.1 Why not other options

Option considered	Rejected because
Keep vanilla JS, add discipline	The failure is structural: mutable global view registry + script-order routing. Discipline does not survive 60 contributors-months
Move to Node/Next in production	Hostinger is shared Apache/PHP. Adds a runtime, a deploy pipeline and a cost, for no user-visible gain
Rewrite the PHP domain too	365 actions encode working business rules. Rewriting them is risk without benefit
Ant Design / MUI	300 kB+ of opinionated components that fight the brand tokens; we need ~25 primitives, which is 600 lines

5.2 Repository layout (proposed, additive)

```
frontend-v1/ <- stays live, untouched during the build
admin-v25/ <- NEW - React + TS source (prototype already here)
src/
lib/ nav.ts - theme.ts - format.ts - api.ts
components/ primitives.tsx - Shell.tsx - CommandPalette.tsx - charts.tsx
screens/ Dashboard.tsx - Leads.tsx - Pipeline.tsx - Quotations.tsx - Theme.tsx ...
styles/ tokens.css - app.css
api/v2/ <- NEW - front controller + handlers
index.php router, envelope, request-id, error boundary
lib/ auth.php db.php store.php caps.php validate.php audit.php http.php
res/ leads.php quotes.php invoices.php clients.php chat.php pages.php ... one per resource
db/migrations/ <- NEW - numbered .sql, forward-only
tests/ <- NEW - route smoke, API contract, migration
```

frontend-v1/admin/ is not deleted until P6 - it is the rollback path.

6. API v2 specification

6.1 Shape

Every response is one envelope. No exceptions, including errors.

```
{ "ok": true,
"data": { },
"meta": { "requestId": "r_8f31c2", "took": 42, "version": "2.5.0" } }
```

```
{ "ok": false,
"error": { "code": "VALIDATION", "message": "Quantity must be greater than zero.",
"field": "lines.3.qty" },
"meta": { "requestId": "r_8f31c2" } }
```

Error codes are a closed set: AUTH, FORBIDDEN, VALIDATION, NOT_FOUND, CONFLICT, RATE_LIMIT, UPSTREAM, INTERNAL. The v2.1 envelope had none of this - admin.php caught only PDOException, so every other throw produced a blank failure with display_errors=0.

6.2 Resource mapping - 365 actions become ~120 endpoints

The rule: **a noun is a resource; a verb becomes a method or a sub-resource.** The v2.1 action names are preserved as an alias table so nothing breaks during migration.

v2.1 actions (examples)	v2 endpoint
leads_list, lead_save, lead_delete, lead_note, lead_convert	GET/POST/PATCH/DELETE /api/v2/leads, /leads/{id}/notes, /leads/{id}/convert

v2.1 actions (examples)	v2 endpoint
quotes_list, quote_get, quote_save, quote_pdf, quote_view	/api/v2/quotations (+ /pdf, /public/{token})
invs_list, inv_save, inv_new, inv_track, pay_add	/api/v2/invoices, /invoices/{id}/payments
clients_master, client_360, clients_merge	/api/v2/clients, /clients/{id}?include=360, /clients/merge
chat_list, chat_get, chat_reply, chat_typing, chat_file	/api/v2/chats, /chats/{id}/messages, /chats/{id}/typing
pages_list, page_new, page_meta_save, page_delete	/api/v2/pages
cms_list, cms_save, cms_published	/api/v2/content/{collection}
wag_get, wag_camp_save, wag_camp_action	/api/v2/whatsapp/campaigns
seo_list, seo_save, seo_scores	/api/v2/seo/pages
media_list, media_upload, media_delete	/api/v2/media
backup_list, backup_run, backup_restore	/api/v2/system/backups

Full mapping ships as api/v2/aliases.php (action name -> route), generated from the existing dispatcher so it cannot drift.

6.3 Auth - the change that matters most

	v2.1	v2.5
Session	HMAC token in sessionStorage, sent as X-WX-ADM	wx_sid HttpOnly - Secure - SameSite=Lax cookie
CSRF	Builder only	X-WX-CSRF double-submit on every non-GET
XSS impact	token readable -> full account takeover	token unreadable by script
2FA	TOTP, retained	TOTP, retained, plus recovery codes shown once
Roles	owner/admin/editor/sales/support, matrix hardcoded in roles-lib.php + JSON grants	same codes, one seeded capability matrix in db/migrations
Rate limit	wx_throttle by IP	same table, plus per-account lockout and an audit entry

6.4 Persistence rules

1. **JSON writes are atomic.** store.php takes flock(LOCK_EX) on an opened handle, writes a temp file, rename()s it, and reads take a shared lock. jread() returns a typed failure instead of an empty array, so the "Admin is not set up yet" 503 can never be caused by a truncated file again.
2. **Money is server-side.** Totals, tax and rounding are computed in PHP; the browser total is labelled a projection (the prototype shows this on the quotations screen).
3. **Secrets never leave the server.** Connector secrets stay write-only; the browser sees the last four characters, as v2.1 already did correctly in conn-lib.php.
4. **Every write is audited** with actor, action, target, request-id and IP into wx_activity.

7. Module and route plan

All 57 v2.1 routes plus 4 new modules, each with the phase that builds it and the module it replaces. Phase **P0** is the prototype already in this repository.

7.1 Route register (abridged - full table in the prototype registry)

Route	Screen	Phase	Replaces	API
dashboard	Master overview	P0 OK	admin-dash.js + admin-p36.js	GET /dashboard
enquiries / leads	Leads table	P0 OK	admin-crm.js	/leads
pipeline	Stage board	P0 OK	admin-p19f.js	/leads?view=board
quotes	Quotations + BOQ builder	P0 OK	admin-sales.js	/quotations
theme	Design tokens	P0 OK	new	-
approvals	Master approval queue	P2	admin-appr.js	/approvals
clients	Client master + 360	P2	admin-sales17.js	/clients
bookings	Site visits and slots	P2	admin-booking.js	/bookings
invoices	Invoices + tracker	P2	admin-sales.js	/invoices
transactions	Payments	P2	admin-sales.js	/invoices/{id}/payments
chat	Unified inbox	P2	admin-chat.js, admin-chat2.js	/chats
users	Users and roles	P2	admin.js, admin-users.js	/users, /roles
activity	Audit log	P2	admin.js	/activity
profile, security	Account	P2	admin-p18j.js, admin-settings.js	/me, /me/2fa
pages, builder, library, global, heroes, redirects	Website control	P3	admin-pages.js, admin-chrome.js, admin-library.js, admin-hero.js, admin-redirects.js	/pages, /blocks, /chrome, /redirects
blog, portfolio, services, cities, pagetpl, faqs, testimonials, logos, team	Content CMS	P3	admin-content.js, admin-fields.js, admin-templates.js, admin-logos.js	/content/{collection}
media, forms, estimator	Assets and capture	P3	admin-media.js, admin-p18e.js	/media, /forms, /estimator
updates, notify	Client updates	P3	admin-notify.js	/notifications
projects, timeline	Delivery	P3	admin-sales.js, new	/projects
templates	Quote templates	P3	admin-print*.js	/quotations/templates
business, integrations	Company and connectors	P3	admin-fields.js, admin-settings.js	/company, /connectors
seo, speed, health, seoagent	Findability and quality	P4	admin-seo.js, admin-seo38.js, admin-speed.js, admin-media.js, admin-seoagent.js	/seo, /speed, /health, /seo/agent
aicenter, train, aireport	AI control	P4	admin-aicenter.js, admin-train.js, admin-aia.js	/ai, /ai/knowledge, /ai/report
whahub, wainsights, wauto, offers, connections	WhatsApp suite	P4	admin-wahub.js, admin-wains.js, admin-p18g.js, admin-offers.js, admin-p38wa.js	/whatsapp/*
telegram, social, gmail	Other channels	P4	admin-tg.js, admin-social.js, new	/telegram, /social, /mail
backups, database, files, maintenance, system	System	P5	admin-media.js, admin-p18h.js, admin-system.js	/system/*

Route	Screen	Phase	Replaces	API
inventory, procurement, portal	v2.5 additions	P6	new	/inventory, /purchase-orders, /portal

7.2 Navigation target - 6 groups -> 8 groups

Group	Routes	Change from v2.1
Home	3	+ Timeline (Gantt)
Sales	11	+ Inventory, Procurement, Client portal
Conversations	10	+ Mail
Website	18	unchanged, regrouped by intent
Automation	4	new group - AI, knowledge, report, SEO agent moved out of Website
System	12	merged Business + Integrations + maintenance
Me	2	unchanged
Total	60	57 -> 60

8. Dashboard content plan

8.1 Widgets and their data source

#	Widget	Source	Refresh	Notes
1	KPI row (4 cards)	GET /dashboard?range=	route load + 60 s poll	Role-aware: money hidden from support
2	Quoted vs won area chart	dashboard.series	route load	12 months, server-aggregated
3	Needs attention feed	computed server-side	60 s	approvals, silent leads, failed campaigns, health regressions
4	Channel mix bars	dashboard.channels	route load	website, WhatsApp, chat, Telegram, phone
5	Service mix table	dashboard.services	route load	count, value, share
6	Latest quotations	/quotations?limit=6	route load	status pills via statusTone()
7	Studio activity	/activity?limit=6	60 s	every write is already audited
8	Quick actions	static	-	six most common studio tasks
9	Approvals banner	/approvals?count	60 s	only for owner/admin/editor
10	Health strip (P4)	/health	daily	score, findings, last scan

8.2 The "needs attention" rule engine

This is the widget that makes the dashboard a tool rather than a report. Each rule is a SQL query with a threshold in wx_settings, so the owner can tune it without a deploy:

Rule	Condition	Severity
Silent lead	stage = new and age > 24 h	amber
Overdue follow-up	next_at < now and stage not won/lost	red
Quotation viewed, not answered	status viewed and 3 days old	amber
Approval waiting	pending > 8 h	amber
Campaign rejected	Meta template status ? approved	red
Backup stale	last backup > 48 h	red
Site health drop	score < previous ? 5	amber
Unanswered AI question	same question x3 and status open	amber

9. Database plan

9.1 What exists (20 tables, 161 columns)

Full schema in the analysis report Section 7. The three structural problems to fix:

1. **Financial documents are opaque.** wx_quotes, wx_invoices, wx_projects, wx_templates store payloads as LONGTEXT JSON, so the database cannot index, query or validate the substance of the business's money.
2. **Authorisation is code, not data.** roles-lib.php hardcodes the entire capability matrix (wx_role_groups(), wx_action_group(), SHARED, EXPAND) and per-user grants live in the JSON side-store _private/security.json, so permissions cannot be inspected, audited or changed without a deploy. *Correction:* an earlier revision of the analysis report called these five *tables* created at runtime and missing from the dump. They are PHP **functions**; the dump's 20 tables are complete. The matrix is still the wrong shape - 001_roles.sql moves it into seeded tables.
3. **wx_leads has 32 columns** and no foreign keys anywhere - integrity is application-only.

9.2 Migration set (forward-only, numbered, one transaction each)

#	Migration	Purpose
001_roles.sql	Move the capability matrix out of roles-lib.php into seeded tables (wx_roles, wx_role_groups, wx_action_groups, wx_user_perms); seed the 5 roles x 9 groups matrix	Closes DB-1
002_indexes.sql	Composite indexes: leads(stage, created_at), leads(next_at, stage), chats(status, updated_at), invoices(no), quotes(no, status), bookings(d, status), activity(created_at, user_id)	Fixes the N+1 and full-scan behaviour reported in the audit
003_document_columns.sql	Add real columns beside the JSON blobs: wx_quotes(client_id, project, subtotal, tax, total, currency, status, issued_at, valid_until, pdf_sha256), same for invoices; backfill from JSON with a one-way script; keep the JSON as payload for compatibility	Makes money queryable
004_fk.sql	Add FKs after cleaning orphans: lead_notes.lead_id -> leads.id, chat_msgs.chat_id -> chats.id, invoices.quote_id -> quotes.id, bookings.lead_id -> leads.id (all ON DELETE CASCADE or SET NULL as appropriate)	Integrity at the database, not in code
005_settings_seed.sql	Seed wx_settings with the attention thresholds and UI defaults	Config, not code
006_inventory.sql	wx_items, wx_stock, wx_stock_moves, wx_suppliers, wx_purchase_orders, wx_po_lines	P6 inventory + procurement
007_portal.sql	wx_portal_tokens, wx_client_approvals, wx_client_uploads	P6 client portal
008_mail.sql	wx_mail_threads, wx_mail_messages	P6 shared mailbox

#	Migration	Purpose
009_versions.sql	wx_page_versions (page, html, note, created_by, created_at)	P3 page history - the plan already references versioning
010_json_retire.sql	Move the remaining 28 _private/*.json stores into wx_kv for the small ones and real tables for the important ones (approvals, whatsapp opt-outs, notifications, redirects, seo)	Ends the non-atomic-store class of bug

9.3 Target size

	Today	After P6
Tables	20	38
Columns	161	~330
Foreign keys	0	14
JSON side-stores	28	0 for business state (5 remain for caches only)

Data safety. Every migration is applied to a restored copy first, with a row-count and checksum comparison before and after, and a dry-run mode. Nothing drops a column in the same release that stops writing to it.

10. Security remediation

The 8 Critical findings must be closed **before** any v2.5 code is deployed. They are listed in order of consequence, not effort.

#	Action	Owner	Verification
1	Rotate the shared demo password (admin account, DB user, any derived key)	Owner	Old value fails on the live host
2	Rotate the Telegram bot token in BotFather	Owner	Old token returns 401 from the Bot API
3	Rotate the application key and maintenance token	Owner	/coming-soon no longer accepts the old token
4	Make the repository private	Owner	gh repo view -> isPrivate: true
5	Remove the login pre-fill and the empty-password fallback (admin/index.html:43, admin.js:235,256)	Dev	Search returns zero hits
6	Remove the admin sign-in hint from downloads.html:70	Dev	Page reviewed
7	Untrack .env, config.php, _private/*; add .gitignore to the pro tree	Dev	git check-ignore lists them
8	Verify private-path 403/404 on the live host, then move state out of JSON (migration 010)	Dev	curl returns 403 for each path

Then the High findings, in P1 and P2:

Finding	Fix	Phase
Non-atomic JSON writes (jwrite truncates before locking)	store.php with flock + temp file + rename	P1
HMAC secret regenerates on empty read, invalidating all sessions	secret stored in MySQL with a checksum; regeneration logged as a Critical event	P1
WhatsApp cron takes a LOCK_NB and admin writers take none	one lock helper used by both; busy becomes a visible 409	P4
Only PDOException caught	an error boundary in the front controller: every throw returns a coded envelope and a request-id	P1
wx-check.php / wx-install.php shipped in production	installer removed from the release artifact; check restricted to owner	P5
143 images without alt text	media library shows a missing-alt queue; health scan links to it	P3

11. Delivery phases

Each phase ends with a **gate**: a written, testable condition. A phase that fails its gate does not start the next one.

Phase 0 - Foundation and prototype - complete - 1 week

Deliverable	Status
Token contract + two themes + accents + densities	OK src/styles/tokens.css
Typed route registry (65 routes, aliases, roles, phases)	OK src/lib/nav.ts
App shell: sidebar, groups, topbar, breadcrumbs, CmdK palette	OK
Five screens: dashboard, leads, pipeline, quotations, theme	OK
Render smoke harness over every route	OK 70 checks - 65 routes - 0 failures
Production build with vendor chunking	OK 80 kB app / 160 kB vendor / 388 kB charts

Gate: npm run verify passes - typecheck, 65-route render test, production build.

Phase 1 - Platform - built - 2 weeks

Work	Deliverable	Status
api/v2 front controller	index.php + lib/{bootstrap,errors,http,store,db,validate,audit,auth,caps,router}.php - router, one envelope, closed error set, error boundary, request-id, CORS-free same-origin	OK 19 files, PHP lint clean
Auth v2	wx_sid HttpOnly - Secure - SameSite=Lax cookie, X-WX-CSRF bound to the session row, 2FA + recovery codes preserved, capability matrix in tables	OK
store.php	JsonStore - sidecar lock, temp+fsync+rename, a corrupt store raises instead of reading as empty	OK
Client api.ts	typed fetch, closed error union, request-id on every failure, timeout, retries on GET only, token in memory	OK
db/migrations/000-005	platform tables, generated role matrix, 12 indexes, document columns, 10 FKs, settings seed - with db/migrate.php --dry-run/--status/--verify	OK
CI	npm run verify + PHP lint + conformance + behavioural tests + migration dry-run	OK .github/workflows/verify.yml

Gate: a signed-in request round-trips cookie -> CSRF -> controller -> MySQL -> envelope; the eight Critical findings are closed and verified.

Verification	Command	Result
PHP parses (no runtime in the build sandbox)	node tools/phplint/php-lint.mjs	103 files clean
Structural invariants (47 checks: auth on every route, envelope discipline, lock discipline, cookie flags, SQL safety, migration guards, the 8 Criticals)	node tests/conformance.mjs	47 passed - 0 failed
Behaviour (84 assertions: paisa money, validation, RFC 6238 TOTP vectors, envelope, aliases, routing, atomic store)	node tools/phpwasm/run-php.cjs tests/run.php	84 passed - 0 failed - 1 skipped
The gate itself, against MySQL	php tests/roundtrip.php	written; runs in CI, needs a database
Prototype	npm run verify	70 render checks - 65 routes - build clean

The two-sided verification is deliberate: tools/phpwasm/run-php.cjs executes the real PHP in the build sandbox (a WebAssembly 8.2 build - the ESM/CJS trap that makes it fail has a note in tools/phpwasm/README.md), and the MySQL leg runs in CI where a real server exists.

Also closed in this phase: the capability matrix moved out of roles-lib.php into seeded tables (tools/gen-caps.mjs regenerates them from the file v2.1 enforced, so the answers cannot differ); the public demo-credential page and the admin/admin installer default are gone; findings 5-8 have executable checks rather than a claim.

Phase 2 - Core operations - 3 weeks

Approvals - clients - bookings - invoices - payments - unified inbox - users and roles - activity - profile - security - leads and pipeline and quotations **port from the prototype to real data**.

Gate: a lead can be created on the website, appear in the inbox, be quoted, approved, invoiced and paid without touching the v2.1 admin. Money totals match the server.

Phase 3 - Content, assets and delivery - 4 weeks

Pages - builder bridge - section library - header/footer - heroes - redirects - the full content CMS - media with alt-text queue - forms - estimator - client updates - projects and the Gantt timeline - quote templates - business info - integrations rebuilt on real connector state - page versioning.

Gate: an editor publishes an article, changes the header across 150 pages, and rolls the change back from page history - all through v2.5.

Phase 4 - Automation and intelligence - 3 weeks

AI centre - knowledge base - AI report - SEO manager and SEO agent - speed - site health - the WhatsApp suite (hub, insights, broadcasts, offers, connection) - Telegram - social planner.

Gate: an AI reply, a WhatsApp campaign and a Telegram alert are all configured, run and observed from v2.5, with the unanswered-question report showing the result.

Phase 5 - System and operations - 2 weeks

Backups (run, list, restore, download) - database browser and export - file manager - maintenance mode - system check - MCP endpoint surface - monitoring page (cron freshness, error rate, slow queries) - release artifact builder with a manifest.

Gate: a restore from backup is performed on a staging copy and the artifact manifest matches the QA run.

Phase 6 - v2.5 differentiators - 4 weeks

Feature	Why it is worth building
Real-time collaboration - SSE for chat, typing, approvals	Removes the 60-second poll that makes two agents fight over one chat
AI scope generator	Parses a brief or floor plan into a draft BOQ; the estimator rate book already exists
Client portal - tokenised, no login	Clients approve BOQs, sign and see renders; the HMAC pattern already exists in quote-view.php
Payment gateways - Stripe, PayFast, JazzCash, EasyPaisa	Manual payment entry is the biggest reconciliation cost in the invoices tracker
Inventory and procurement	Timber, acrylic, hardware and fabric tracking with purchase orders on milestone thresholds
Shared mailbox	Ends the "who replied to this client" question

Gate: a client, without an account, opens a portal link, approves a quotation and pays a deposit; the invoice reconciles itself; stock is drawn down against the project.

---

12. Schedule and effort

Assumes **2 developers** (one front end, one PHP/back end) plus the owner for decisions and credential rotation.

Phase	Effort (person-weeks)	Calendar (2 devs)	Cumulative
P0 Foundation OK	1	week 1	week 1
P1 Platform	3	weeks 2-3	week 3
P2 Core operations	5	weeks 4-6	week 6
P3 Content and delivery	6	weeks 7-10	week 10
P4 Automation	4	weeks 11-13	week 13
P5 System	3	weeks 14-15	week 15
P6 v2.5 differentiators	6	weeks 16-19	week 19
Total	28		

Critical path: P1 auth and store.php -> P2 core operations -> P3 pages. Any slip in P1 delays everything; P4 and P5 can run in parallel with P6 if a third developer joins.

With one developer: ~ 7 months. Recommendation: do not start P6 before P5; ship P0-P2 (6 weeks) first - that alone replaces the entire daily-operations surface.

12.1 Cost of not doing it

Cost	Evidence
Support time lost to "which build is live?"	Four admin generations, three near-identical v2.1 trees
Data-loss risk	Non-atomic JSON writes over 28 stores
Security exposure	8 Critical findings, public repository, published credentials
Feature velocity	No build step; 67 unversioned script tags; last-script-wins routing

13. Testing and QA strategy

Layer	Tool	Scope	Runs
Types	tsc --noEmit	every TS module	every push
Render smoke	src/smoke.tsx (built)	every route x every role	every push
Token contract	tests/tokens.test.ts	fails if a component contains a hex colour or a non-semantic var()	every push
API contract	tests/api/*.http	each endpoint: 200 happy path, 401 unauthenticated, 403 wrong role, 422 invalid	every push
Migration	tests/db/migrate.sh	apply to a restored copy, compare row counts and checksums, then dry-run	before each release
Money	tests/money.test.php	quotation and invoice totals against 30 recorded cases	every push
Accessibility	axe via a headless run	the 8 most-used screens	weekly
Performance	bundle budget	app <= 150 kB gz, charts lazy-loaded	every push

Bundle budget. The prototype measured 80 kB app + 160 kB vendor + 388 kB charts (uncompressed). Charts load only on screens that need them, which is why the chunk exists.

Regression rule. Every defect found after P1 gets a failing test before it gets a fix. The v2.1 audit produced 60 unique defect IDs; ten of them become permanent tests in P1 and P2.

14. Deployment and rollback

14.1 Target topology (unchanged hosting)

```
public_html/
index.html - 404.html - 500.html - 503.html - robots.txt - sitemap.xml
about/ contact/ insights/ projects/ ... 150 public pages (unchanged)
admin/ <- React build output: index.html + assets/*.[hash].js|css
api/v2/ <- PHP front controller + handlers
assets/ uploads/ backups/
_private/ <- denied by .htaccess AND by a PHP guard
.htaccess
```

.htaccess additions for the SPA: history fallback inside /admin/ only, so a deep link such as /admin/leads serves admin/index.html while the API and the public site are unaffected.

14.2 Cut-over strategy - strangler

Step	Action	Rollback
1	Deploy api/v2 alongside api/. Both write the same MySQL.	Delete the folder
2	Deploy the React admin at /admin-next/, reachable by staff only	Delete the folder
3	Enable screens one group at a time via wx_settings.admin_v25_routes	Flip the setting
4	When coverage is complete, point /admin/ at the new build (302)	Restore the old admin/
5	After 14 stable days, remove frontend-v1/admin/ from the release	Restore from the artifact

At every step the v2.1 admin remains functional against the same data.

14.3 Release artifact

One zip per release with a manifest: git SHA, build hash, asset hashes, migration list applied, QA result summary, and the rollback commit. The v2.1 audit's packaging gate failed because QA results did not match a packaged artifact; the manifest is the fix.

---

15. Risk register

#	Risk	Likelihood	Impact	Mitigation
R1	Credentials leak is exploited before rotation	Medium	Severe	Rotation is step 1 of P1, owner-owned, before any code deploys
R2	Rewrite drifts from the 365 existing actions	Medium	High	The alias table is generated from the live dispatcher, not written by hand
R3	Team keeps using the old admin during the transition	High	Medium	Old admin shows a banner once a screen has a v2.5 equivalent
R4	Migration corrupts documents during backfill	Low	Severe	Dry-run + checksums + restore-tested on a copy; JSON kept as payload
R5	Bundle grows past budget	Medium	Low	Budget enforced in CI; charts lazy-loaded
R6	Hostinger .htaccess quirks break the SPA fallback	Medium	Medium	Fallback scoped to /admin/; tested on a staging subdomain first
R7	Scope creep from the 12 open audit items	High	Medium	P6 is the only phase that takes new scope; P1-P5 are frozen at the gate
R8	Single developer becomes the bottleneck	Medium	High	P1 and P2 have no front-end-only work by design; the registry is data, not code

---

16. What the prototype already proves

Everything in admin-v25/ runs today:

Evidence	Result
Type check	clean, strict, noUnusedLocals
Render smoke	70 checks - 65 routes - 0 failures
Production build	3 chunks, content-hashed, sourcemaps on
Token contract	switching theme, accent and density re-themes all charts and screens
Routing defects	AD-3, AD-4 and AD-12 structurally impossible in the registry
Money honesty	the quotations screen labels the browser total a projection and names the endpoint
Accessibility	kanban cards move with <- / ->, not only by drag; aria-current on navigation; visible focus rings

Run it:

```
cd admin-v25 && npm install && npm run dev # http://localhost:5173
npm run verify # typecheck + 65-route smoke + build
```

17. Decisions still needed from you

#	Decision	Options	Recommendation
1	Invoice print designs	one design (today) - match the three quotation designs	Build three; invoices are the document clients keep
2	Section library	51 blocks - build the 19 missing to reach the 70-block suite	Build them in P3 - they are the fastest content wins
3	Follow-the-system theme	last explicit choice - follow the OS	Last explicit choice, with a reset button
4	Repository visibility	public - private	Private - this is a Critical finding
5	Payment gateway	Stripe - PayFast - JazzCash - EasyPaisa	Start with PayFast (cards + local) in P6
6	Client portal scope	view + approve - add uploads and payments	Approve + payments first; uploads in P6.5

18. Conclusion

The fastest way to a master dashboard that the studio can rely on is **not** to rewrite the business logic that already runs a real business, and **not** to keep patching an interface whose routing model cannot be repaired. It is to replace the interface, version the API, migrate the side-stores into the database, and ship one screen group at a time behind a flag.

Six weeks of work gets the entire daily-operations surface - leads, pipeline, quotations, invoices, chat, approvals - onto the new admin with the Critical findings closed. Nine more weeks add content, automation, system control and the v2.5 features that make the product worth paying for.

Everything measured here is in PROJECT-ANALYSIS-REPORT-2026-10-13.pdf; everything designed here is runnable in admin-v25/.

Appendix A - delivery gate checklist

Every phase must satisfy all six before the next begins.

- [ ] **Scope** - every screen in the phase renders for every permitted role
- [ ] **Empty** - every list has a designed empty state; every form has a designed error state
- [ ] **Data** - no screen reads a JSON side-store that migration 010 has retired
- [ ] **Money** - any figure that reaches a client document is server-computed
- [ ] **Access** - no literal colour; contrast >= 4.5:1 on text; keyboard reachable
- [ ] **Evidence** - npm run verify green, screenshots or test output attached to the phase report

Appendix B - semantic token list (33)

```
surfaces --bg --surface --surface-2 --surface-3 --surface-inset --sidebar --sidebar-hover
--sidebar-active
lines --border --border-strong
text --text --text-muted --text-subtle --text-on-accent --text-on-sidebar --text-on-sidebar-muted
accent --accent --accent-hover --accent-soft --accent-ink --accent-ring
status --ok --ok-soft --warn --warn-soft --danger --danger-soft --info --info-soft --neutral-soft
brand --brand --brand-soft
charts --viz-1 ... --viz-6 --grid
elevation --shadow-sm --shadow-md --shadow-lg --overlay
shape --r-xs --r-sm --r-md --r-lg --r-xl --r-full
space --s-1 --s-2 --s-3 --s-4 --s-5 --s-6 --s-8 --s-10 --s-12
type --font --font-mono --fs-11 ... --fs-28 --lh-tight --lh-snug --lh-normal
motion --dur-1 --dur-2 --dur-3 --ease
layout --sidebar-w --sidebar-w-mini --topbar-h --row-h --s-page --control-h --fs-body
depth --z-base --z-sticky --z-drawer --z-modal --z-palette --z-toast
```

Appendix C - commands

```
# prototype
cd admin-v25
npm install
npm run dev # http://localhost:5173 (binds 0.0.0.0)
npm run verify # typecheck + 65-route render smoke + production build
npm run smoke # render smoke only

# regenerate this document's PDF
python3 tools/report2pdf.py ADMIN-V2.5-MASTER-PLAN-2026-10-13.md \
ADMIN-V2.5-MASTER-PLAN-2026-10-13.pdf "Admin v2.5 Pro" \
"Master Dashboard - React + TypeScript - Phased Delivery" \
--meta "Strategy=Rewrite the front end - version the back end - preserve the data" \
--meta "Prototype=admin-v25 - 65 routes, 70 render checks, 0 failures" \
--footer "Woodex Admin v2.5 Pro Master Plan - 13 Oct 2026 - Confidential"
```

End of plan - 13 October 2026.